

B3 CS Infras Réseau Sécurisées > TPs > TP2 - Offensive Sec

TP2 Part 1 : DHCP attacks

DHCP. Casser. 🐱

1. DHCP spoofing

A. Intro

Une attaque qui consiste à se faire passer pour le serveur DHCP du réseau et donc contrôler les infos DHCP que reçoit le client.

Pas besoin d'outil de fou : juste monter un serveur DHCP sur la machine attaquante, et répondre plus vite que le serveur légitime !

Info

Avec notre base setup, ça permet de se faire passer pour le serveur DHCP auprès de `bowser`, et donc on contrôle : son IP, l'adresse qu'il enregistre comme passerelle, et l'adresse qu'il enregistre comme DNS.

Une fois l'attaque menée, on est en MITM entre le client et le reste du monde.

Z'est bardi.

B. Setup

→ Introduire une nouvelle VM dans la topologie, OS de votre choix

- ce sera notre machine attaquante
- branchez-la au même switch que `bowser`, notre victime
- installer un serveur DHCP sur la machine attaquante : ce sera notre "**rogue DHCP server**" (serveur DHCP malveillant)



→ Installez et configurez un serveur DHCP sur votre machine attaquante

- il doit uniquement faire serveur DHCP (car il peut aussi faire serveur DNS)
- il doit attribuer dans une plage bien spécifique, pour repérer facilement l'attaque (genre `10.1.10.250` à `10.1.10.253`)

 Hint

Je recommande d'utiliser le serveur DHCP `dnsmasq` (ui il peut faire serveur DHCP malgré son nom).

→ Test !

- d'abord, stoppez le service DHCP "légitime" sur la machine `dhcp.tp1.efrei`
- vérifier qu'un client (VPCS) récupère bien une adresse IP dans la range configurée avec `dnsmasq` de la machine attaquante
- on vérifie d'abord chill que la machine attaquante fait correctement tourner un serveur DHCP

C. Race !

→ Now race !

- rallumez le serveur DHCP légitime
- demandez une IP avec un client (VPCS) et voyez qui répond
- faites-le plusieurs fois pour voir si c'est consistant
- je vous conseille de pop un nouveau VPCS à chaque fois, c'est très rapide

→ Wireshark this please

- **gagnez la course avec la machine attaquante contre le serveur DHCP légitime** 🚲
- capturez cette course :d
- je recommande de lancer Wireshark entre le client et son switch
- on doit voir :
 - le *Discover* du client
 - les deux serveurs DHCP qui répondent un *Offer*
 - la suite de l'échange qui se déroule entre le client et la machine attaquant (e.g. gagner la course)

🐞 Capture `p1_dhcp_race.pcap`

Info

Si on met vraiment l'attaque en place et qu'on veut gagner la course, **on n'hésite pas à mettre un coup de batte dans les jambes du concurrent** : essayer de ralentir le serveur DHCP légitime.

On abordera ça plus tard maybe, je vous invite fort à faire des recherches sur le sujet : comment ralentir une machine qu'on peut joindre sur le réseau, et spécifiquement un serveur DHCP ici.

D. Manually

La même chose, mais avec votre propre code :)

📄 Script `dhcp_race.py`

- un script Scapy qui simule un serveur DHCP pour répondre illégalement à des clients
- essayez de faire au plus simple pour qu'il soit au plus rapide possible
- on préférera donc des trucs tout sales tout hardcodés, à des comportements riches et complexes (mais trop lents)

2. DHCP starvation

A. Intro

Une attaque très débile et simple à mettre en place pour **DOS l'accès à un LAN** s'il n'y a pas de protections particulières. **C'est naze, mais c'est là** :d

Le principe est simple : **faire de multiples échanges DORA avec le serveur DHCP pour demander plein d'adresses IP, et ainsi récupérer toutes les IP disponibles dans le réseau.**

On usurpe une adresse MAC (qu'elle existe ou non), on demande une adresse IP au serveur DHCP, on la récupère (merci). On répète l'opération avec une nouvelle fake adresse MAC, une nouvelle IP (merci). Etc.

Jusqu'à épuiser toutes les adresses de la range.

Il existe des tools pour faire ça, vous pouvez aussi essayer de le **coder vous-mêmes avec Scapy** (une dinguerie cette lib Python) : on peut forger à peu près tout et n'importe quoi comme trame, et très facilement, avec Scapy.

B. Attack

→ Depuis votre machine attaquante, effectuez un DHCP starvation

- vous devez saturer la plage d'adresse IP configurée sur `dhcp.tp1.efrei`
- vous devez donc demander plein d'adresses IP
- vous le faites avec un **script Scapy**

📄 Script `dhcp_starvation.py`

- un script Python Scapy qui effectue un DHCP starvation
- il prend en argument :
 - l'adresse IP du serveur DHCP à cibler
 - l'adresse du réseau à saturer
- par exemple, on peut l'appeler comme ça :

```
# python dhcp_starvation.py <DHCP_SERVER> <NETWORK>
python dhcp_starvation.py 10.1.30.1 10.1.30.0/24
```



C. Capture

→ Capture du DHCP starvation

- Wireshark sur le câble entre la machine attaquante et son switch par exemple
- un bon gros spam de trames de la machine attaquante
- toutes les trames nécessaires pour remplir la plage d'adresse disponibles

🐾 Capture `p1_dhcp_starvation.pcap`

→ Capture d'un client qui n'a pas accès au réseau : il est DOS le fréro

- Wireshark sur le câble entre le client et son switch par exemple
- après l'attaque effectuée, demandez une adresse IP depuis un client
- capturer l'échange
- vous verrez que le *DORA* ne se passe pas correctement : le serveur DHCP informe le client qu'il n'y a plus d'adresses IP dispo (déso bro)

 Capture `p1_dhcp_dos.pcap`

→ **La suite du programme : attaques sur ARP**